

CINNAMON GRAND COLOMBO - LOYALTY HUB SYSTEM

SECURITY ASSESSMENT
SCOPE
Classification:
CONFIDENTIAL

Target System Scope & Security Architecture Dossier

Prepared specifically for Third-Party Vulnerability Assessors, Penetration Testers, and Security Auditors. This dossier provides a comprehensive specification of application attack surfaces, system topologies, frontend routes, backend microservice controllers, and all **80 connected API endpoints**.

Target System:	Cinnamon Grand Loyalty Hub & Benefits Platform	Audit Baseline:	October 2026 / Version 1.0
Target Audience:	Third-Party Vulnerability Tester / Auditor	Scope Mode:	Gray-Box / White-Box Web & API Audit
UAT Environment:	https://cinnamon-uat.text-ware.com	Ingress Gateway:	Nginx Reverse Proxy (Port 7257)
Backend Services:	4 NestJS Microservices (Ports 3001-3004)	Persistence:	PostgreSQL 15+ & Redis Cache (Rate Limit)
Frontend App:	React 18 + TypeScript + Vite (Port 8080)	Total API Count:	80 REST Endpoints (12 Controllers)

1. Executive Summary & Assessment Inventory

The Cinnamon Grand Loyalty Hub is a full-featured enterprise hospitality platform handling corporate partner agreements, employee privilege accounts, point-of-sale discount calculations, voucher redemptions, OTP-based bill verifications, and omnichannel member messaging. For testing scoping, the attack surface is categorized into 5 distinct assessment pillars:

Assessment Pillar	Components / Technologies	Scope Metric	Primary Auditor Objective
1. Frontend Client Tier	React 18, TypeScript, Vite, TailwindCSS, Redux Toolkit	8 URL Routes 17 Functional Views	XSS audit, CSRF resilience, client-side session storage leakage, client-enforced permission bypass.
2. Ingress API Gateway	Nginx Ingress Reverse Proxy, SSL/TLS, Upstream Load Balancer	Port 7257 2 Rate Limiting Zones	Edge rate-limiting bypass, HTTP request smuggling, proxy header spoofing (X-Forwarded-For, X-Real-IP).
3. Backend Microservices	Node.js, NestJS 10+, TypeScript, Express engine	4 Microservices 80 API Endpoints	BOLA/IDOR, broken function-level auth, privilege escalation, mass assignment, injection (SQLi), rate limiting.
4. Persistence & Cache	PostgreSQL 15+ (Relational), Redis (Sliding-window token bucket)	24 Migration Schemas Atomic Lua Rate Scripts	Database parameterization verification, SQL injection vectors, Redis key collisions, OTP brute-force safety.
5. External Cloud Integrations	TextWare SMS Gateway, TextWare WhatsApp API, SendGrid SMTP	4 External Providers Egress HTTPS/TLS	Credential exposure, SSRF, outbound webhook replay, downstream service denial of service handling.

2. System Architecture & Threat Surface Topology

The following architectural map illustrates the multi-tier deployment topology, reverse proxy routing rules, cross-cutting security guards, inter-service ports, database connections, and external third-party boundaries:

CINNAMON GRAND LOYALTY HUB - SYSTEM ARCHITECTURE & THREAT SURFACE MAP

Target Scope Architecture for Third-Party Penetration Testing (Network Topologies, Microservices, Ingress & Security Boundaries)

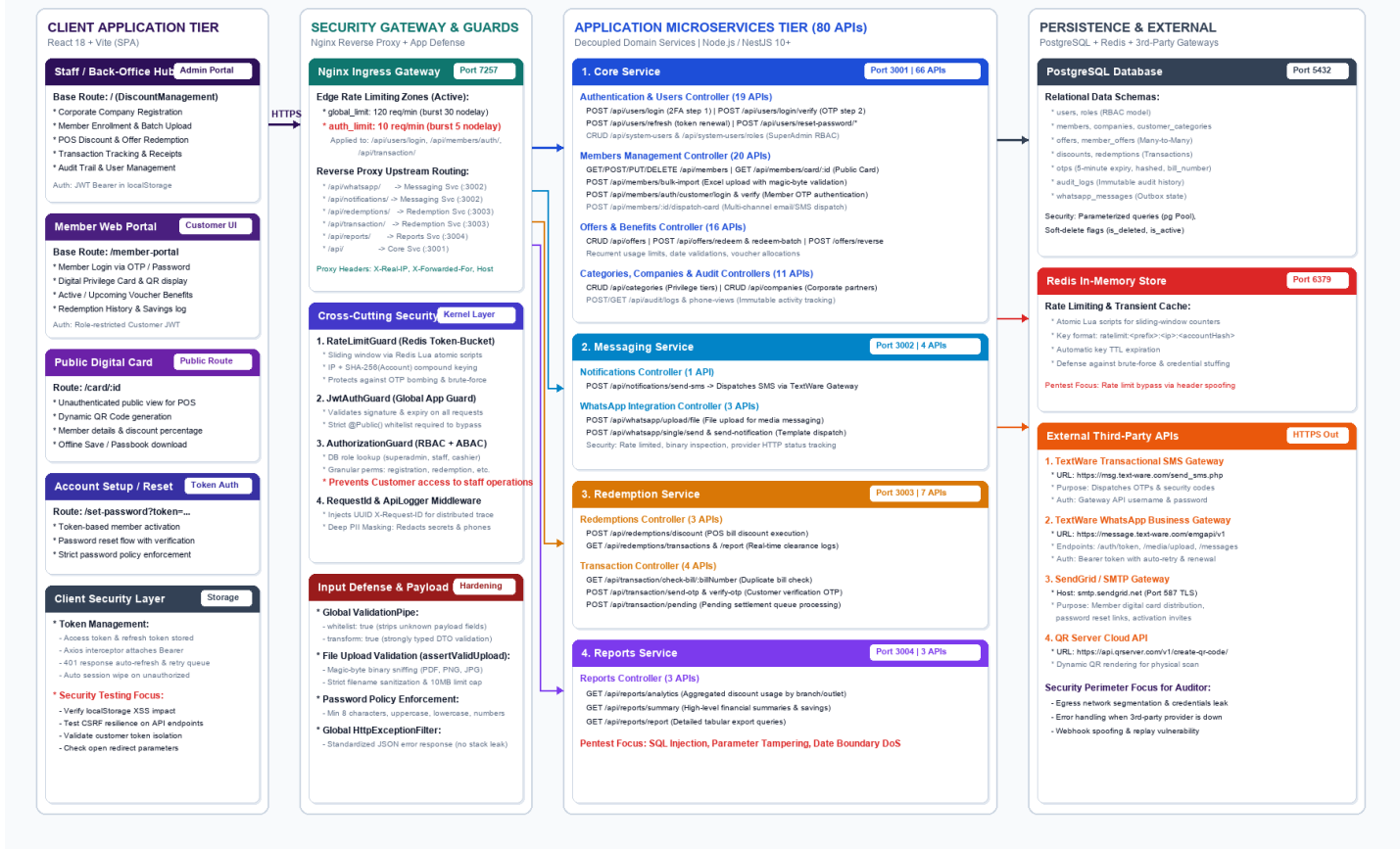


Figure 2.1: End-to-End System Architecture, Upstream Gateway Routing & Security Guards.

Architectural Security Highlights for Auditors:

- Edge Ingress (Nginx :7257):** Terminates incoming traffic and applies rate-limiting zones: global_limit (120 req/min, burst 30 nodelay) and auth_limit (10 req/min, burst 5 nodelay) to sensitive auth paths before forwarding to upstreams.
- Application Microservices Tier:** Divided into 4 domain services: **Core Service (:3001)** [Identity, Members, Offers, Admin], **Messaging Service (:3002)** [SMS & WhatsApp], **Redemption Service (:3003)** [POS Bill Verification & OTP], and **Reports Service (:3004)** [Aggregations].
- Zero-Trust Cross-Cutting Guards:** Global NestJS guards enforce Redis-backed sliding-window rate limiting (RateLimitGuard), signature-verified JWT token checks (JwtAuthGuard), and strict role/permission checks (AuthorizationGuard).
- Defense-in-Depth Layer:** Global ValidationPipe (whitelist: true, transform: true), magic-byte file inspection (assertValidUpload), and PII masking middleware (ApiLoggerMiddleware).

3. Frontend Architecture & Client-Side Surface

The frontend is implemented as a modern Single-Page Application (SPA) using React 18, TypeScript, and Vite. Client-side routing is managed through react-router-dom v6. Session tokens (Access Token & Refresh Token) and user metadata are maintained in browser localStorage, with Axios request/response interceptors automatically attaching the Authorization: Bearer <token> header and orchestrating seamless background token refresh.

3.1 Frontend Folder Structure (cinnamon-loyalty-hub/)

```
cinnamon-loyalty-hub/
|-- public/                # Static assets, Cinnamon logos, robots.txt
|-- src/
|   |-- app/
|   |   |-- apiManager.ts    # Axios singleton, request interceptor, JWT bearer, 401 refresh queue
|   |   |-- assets/          # Brand artwork & SVG icons
|   |   |-- components/
|   |   |   |-- common/      # Shared reusable components
|   |   |   |-- discount/    # Admin & Staff management modules (Registration, Redemption, Offers...)
|   |   |   |-- ui/          # Radix UI primitive design system (Modal, Tabs, Table, Dialog...)
|   |   |   |-- DiscountManagement.tsx # Core Staff Hub shell (tab container & permission checks)
|   |   |-- constants/      # Application message constants & validation strings
|   |   |-- hooks/          # Custom React hooks (useMobile, useDebounce, useToast)
|   |   |-- pages/          # Route entry components (Index, Login, MemberPortal, DigitalCard...)
|   |   |-- services/       # Frontend HTTP API service layers (auditApi, memberApi, offerApi...)
|   |   |-- store/          # Redux Toolkit state slices (authSlice, session state)
|   |   |-- utils/          # Utility helpers (auditLogger, phoneUtils, country codes)
|   |   |-- App.tsx         # Route table definition (, , )
|   |   |-- main.tsx        # DOM root mount & Redux Provider initialization
|   |-- .env               # Vite environment configuration (API base URL, SMS gateway keys)
|-- vite.config.ts         # Vite bundler, proxy configuration & path aliases (@/ -> src/)
```

3.2 Configured URL Route Catalog (8 Routes)

Route Path	Target Component	Access Control	Description & Pentest Attack Surface
/	Index.tsx	Authenticated (Staff or Member)	Smart entry hub: unauthenticated redirected to /login; members render MemberPortal; staff render DiscountManagement.
/login	Login.tsx	Public (Staff / Admin)	Staff credential authentication: username + password, step-1 and step-2 OTP verification. Test for brute force and user enumeration.
/login-member	MemberLogin.tsx	Public (Customer)	Customer loyalty login: Mobile/email input with SMS/Email OTP or password verification. Test OTP brute force and rate limiting.
/member-portal	MemberPortal.tsx	Authenticated (Customer role)	Customer self-service dashboard: digital card QR, available vouchers, transaction logs. Test horizontal privilege escalation (BOLA).
/set-password	SetPassword.tsx	Public (Activation Token)	Activation & password setup: reads ?token=... parameter, validates against backend, sets new password. Test token entropy & replay.
/card/:id	DigitalCard.tsx	Public (Tokenized ID)	Public digital card pass: renders dynamic QR code and privileges for physical scanning at restaurant/hotel. Test IDOR on :id parameter.
/card	NotFound.tsx	Public (Fallback)	Fallback redirection for missing card identifier parameters.
*	NotFound.tsx	Public (Catch-all)	Global 404 handler for non-existent paths. Verify error page does not reflect unescaped URL input (XSS).

3.3 Functional Screen & Module Catalog (17 Distinct Views)

#	Screen / Module Name	Parent Container / Route	Target Component File	Role / Required Permission
1	Company Registration	/ (Tab: registration)	CompanyRegistration.tsx	Admin / registration
2	Member Enrollment & Batch Upload	/ (Tab: registration)	BulkUploadWidget.tsx	Admin / registration
3	Discount Redemption Counter	/ (Tab: redemption)	Redemption.tsx	Staff / redemption
4	Offer & Voucher Redemption	/ (Tab: redemption)	OfferRedemption.tsx	Staff / redemption
5	QR Scanner Dialog	/ (Redemption modal)	QrScannerDialog.tsx	Staff / redemption
6	Transaction Tracking & History	/ (Tab: transactions)	TransactionTracking.tsx	Staff / transactions
7	Reports & Business Analytics	/ (Tab: reports)	ReportsAnalytics.tsx	Staff / reports
8	Member Categories Management	/ (Tab: categories)	CustomerCategoryManagement.tsx	SuperAdmin / settings_categories
9	Offer Management & Rules	/ (Tab: offers)	OfferManagement.tsx	SuperAdmin / settings_offers
10	Multi-Channel Notifications	/ (Tab: notifications)	SendNotifications.tsx	SuperAdmin / settings_notifications
11	WhatsApp Composer & History	/ (Tab: notifications)	WhatsappComposer.tsx	SuperAdmin / settings_notifications
12	System Audit Trail & Compliance	/ (Tab: audit)	AuditTrail.tsx	SuperAdmin / settings_audit
13	User & Role Administration	/ (Tab: usermanagement)	UserManagement.tsx	SuperAdmin only
14	Member Privilege Card Screen	/member-portal	MemberPortal.tsx	Customer / Member
15	Staff Login Screen	/login	Login.tsx	Public
16	Member OTP Login Screen	/login-member	MemberLogin.tsx	Public
17	Public Digital Card View	/card/:id	DigitalCard.tsx	Public

4. Backend Architecture & Directory Structure

The backend is developed with NestJS 10+ and TypeScript, organized into four decoupled domain microservices behind an Nginx ingress reverse proxy. The codebase uses strict modular encapsulation, centralized database connection pooling via node-postgres (pg), global validation filters, and cross-cutting security guards.

4.1 Backend Folder Structure (cinnamon-loyalty-backend/)

```
cinnamon-loyalty-backend/
|-- migrations/           # 24 SQL migration scripts (schema definition, roles, indexes, seeds)
|-- nginx/               # Gateway configuration (nginx.conf - rate limiting, proxy headers)
|-- src/
|  |-- common/           # Shared cross-cutting components across microservices
|  |  |-- decorators/    # @Roles(), @RequirePermissions(), @RateLimit(), @PublicRoute()
|  |  |-- filters/       # HttpExceptionFilter (Standardized sanitized error JSON responses)
|  |  |-- guards/        # RateLimitGuard (Redis-backed atomic Lua sliding window)
|  |  |-- logging/       # ApiLoggerMiddleware, RequestIdMiddleware, PII-masking utils
|  |  |-- sms-gateway.ts  # Centralized TextWare SMS dispatch integration
|  |  |-- core/
|  |  |  |-- audit/      # Audit logging controller & service (Immutable compliance tracking)
|  |  |  |-- auth/       # Staff authentication, OTP generation, token refresh, reset password
|  |  |  |-- categories/ # Customer tier categories & discount eligibility rules
|  |  |  |-- companies/  # Corporate partner company profiles & discounts
|  |  |  |-- database/   # PostgreSQL connection pool (pg.Pool) & migration bootstrap
|  |  |  |-- members/    # Member CRUD, bulk Excel import, OTP login, card dispatch
|  |  |  |-- offers/     # Offer vouchers, campaign rules, redemptions & reversal handling
|  |  |  |-- users/      # System user admin, profile management, role & permission ACL
|  |  |  |-- core.module.ts # Core dependency injection root with global APP_GUARD providers
|  |  |  |-- main.ts     # Core service bootstrap (Port 3001)
|  |  |-- messaging/     # Messaging Microservice (Port 3002 | 4 API Endpoints)
|  |  |  |-- notifications/ # Outbound SMS notification controller
|  |  |  |-- whatsapp/     # TextWare EMG WhatsApp API integration & secure file upload handler
|  |  |  |-- main.ts       # Messaging service bootstrap (Port 3002)
|  |  |-- redemption/    # Redemption Microservice (Port 3003 | 7 API Endpoints)
|  |  |  |-- redemptions/  # POS discount redemptions, transaction recording, settlement logs
|  |  |  |-- transaction/  # Bill verification, cashier transaction OTP generation & verification
|  |  |  |-- main.ts       # Redemption service bootstrap (Port 3003)
|  |  |-- reports/       # Reports Microservice (Port 3004 | 3 API Endpoints)
|  |  |  |-- reports.controller.ts # Analytics aggregations, branch usage trends, data export
|  |  |  |-- main.ts       # Reports service bootstrap (Port 3004)
|  |  |-- utils/         # Security utils (fileValidation.ts, passwordPolicy.ts, phoneUtils.ts)
|  |-- .env.example      # Environment variables template (JWT secrets, DB credentials, API keys)
|-- Dockerfile           # Multi-stage container deployment
```

5. Security Controls & Authentication Architecture

Security Mechanism	Implementation Details	Threat Mitigation & Pentest Notes
Dual-Persona Auth Model	Staff: Username/password login -> optional OTP 2FA -> JWT Bearer with roles (superadmin, staff, cashier). Customer: Mobile/email OTP or password -> JWT with role: customer.	Horizontal Escalation: Verify customers cannot access staff APIs. AuthorizationGuard strictly isolates customer role tokens.
JWT & Refresh Tokens	- Signed with HMAC SHA-256 (JWT_SECRET). - Short-lived access token + Refresh token rotation via /api/users/refresh.	Token Vulnerabilities: Test for algorithm confusion (none/HS256), expired token acceptance, and refresh token replay.
Redis Rate Limiting	- Key format: ratelimit:<prefix>:<ip>:<sha256(account)>. - Atomic Lua evaluation in Redis. - Nginx gateway limits: 120 r/m global, 10 r/m auth.	Brute-Force Defense: Test OTP cracking on /api/transaction/verify-otp and credential stuffing on /api/users/login.

Deep File Inspection	- Enforced in assertValidUpload. - Magic-byte binary sniffing (verifies genuine PDF/image header bytes). 10MB size limit & extension whitelist.	Malicious Uploads: Test MIME-type spoofing, polyglot files, zip-bombs, and path traversal via originalname in upload.
Input Validation (DTOs)	- NestJS ValidationPipe({ whitelist: true, transform: true }). - Rejects unexpected payload properties.	Mass Assignment: Test if extra fields (e.g. role: superadmin) can be injected into registration or update payloads.
PII Masking & Audit Trail	- ApiLoggerMiddleware sanitizes passwords, tokens, and phone numbers before writing to logs. - Immutable audit_logs table.	Sensitive Data Exposure: Verify log files and error responses do not leak database credentials, tokens, or PII.

6. Comprehensive REST API Inventory & Attack Surface (80 Endpoints)

This section documents all **80 REST API endpoints** implemented in the backend across all 12 controllers. For each endpoint, the HTTP method, route path, authentication/authorization requirements, rate limiting status, and primary penetration testing focus areas (OWASP API Top 10 vulnerabilities) are specified.

6.1 Core Service - audit.controller.ts (4 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
POST	/api/audit/logs	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Audit log tampering, log injection (CRLF), unauthorized log viewing, PII leak in event details.
GET	/api/audit/logs	JWT Bearer (Auth)	Nginx Edge (120r/m)	Audit log tampering, log injection (CRLF), unauthorized log viewing, PII leak in event details.
POST	/api/audit/phone-views	JWT Bearer (Auth)	Nginx Edge (120r/m)	Audit log tampering, log injection (CRLF), unauthorized log viewing, PII leak in event details.
GET	/api/audit/phone-views	JWT Bearer (Auth)	Nginx Edge (120r/m)	Audit log tampering, log injection (CRLF), unauthorized log viewing, PII leak in event details.

6.2 Core Service - auth.controller.ts (6 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
POST	/api/users/login	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/users/login/verify	Public (No JWT)	Redis Guard + Nginx	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/users/login/resend	JWT Bearer (Auth)	Redis Guard + Nginx	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/users/reset-password/request	Public (No JWT)	Redis Guard + Nginx	Token entropy, token replay, token expiration bypass, email header injection, password complexity check.
POST	/api/users/reset-password/verify	Public (No JWT)	Redis Guard + Nginx	Token entropy, token replay, token expiration bypass, email header injection, password complexity check.
POST	/api/users/refresh	Public (No JWT)	Redis Guard + Nginx	Refresh token reuse detection, revocation check, signature tampering, JWT expiry bypass.

6.3 Core Service - categories.controller.ts (4 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
GET	/api/categories	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/categories	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
PUT	/api/categories/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
DELETE	/api/categories/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.

6.4 Core Service - companies.controller.ts (3 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
GET	/api/companies	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/companies	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
PUT	/api/companies/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.

6.5 Core Service - members.controller.ts (20 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
GET	/api/members	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
GET	/api/members/phone/:phone	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
GET	/api/members/code/:code	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
POST	/api/members	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
PUT	/api/members/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
DELETE	/api/members/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
GET	/api/members/card/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
GET	/api/members/:id/portal-data	Public (No JWT)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
POST	/api/members/:id/send-card	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
POST	/api/members/:id/dispatch-card	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
POST	/api/members/bulk-validate	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/members/bulk-import	JWT Bearer (Auth)	Nginx Edge (120r/m)	Malicious file upload, magic-byte bypass, CSV/Excel formula injection (XXE), path traversal, DoS via large file.
GET	/api/members/auth/verify-token	JWT Bearer (Auth)	Nginx Edge (120r/m)	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/members/auth/set-password	Public (No JWT)	Nginx Edge (120r/m)	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/members/auth/customer/login	Public (No JWT)	Nginx Edge (120r/m)	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/members/auth/customer/login/verify	Public (No JWT)	Redis Guard + Nginx	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/members/auth/customer/otp/resend	Public (No JWT)	Redis Guard + Nginx	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/members/auth/customer/reset-password/request	Public (No JWT)	Redis Guard + Nginx	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.

POST	/api/members/auth/customer/reset-password/verify	Public (No JWT)	Redis Guard + Nginx	Credential stuffing, brute-force OTP, rate-limit bypass, session fixation, token signature validation.
POST	/api/members/:id/send-password-reset-email	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.

6.6 Messaging Service - notifications.controller.ts (1 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
POST	/api/notifications/send-sms	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	SMS/WhatsApp bombing, international destination abuse, toll fraud, template variable injection, payload spoofing.

6.7 Core Service - offers.controller.ts (16 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
GET	/api/offers	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/offers	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
PUT	/api/offers/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
DELETE	/api/offers/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
GET	/api/offers/available	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/offers/redeem	JWT Bearer (Auth)	Nginx Edge (120r/m)	Financial race conditions (double spend), concurrent redemptions, negative value tampering, discount limit bypass.
POST	/api/offers/redeem-batch	JWT Bearer (Auth)	Nginx Edge (120r/m)	Financial race conditions (double spend), concurrent redemptions, negative value tampering, discount limit bypass.
GET	/api/offers/redemptions	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
GET	/api/offers/category/:categoryId	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
GET	/api/offers/:id/categories	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
POST	/api/offers/reactivate	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
GET	/api/offers/active-redemptions	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/offers/assign-to-members	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/offers/fix-member-offers	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/offers/reverse/request	JWT Bearer (Auth)	Nginx Edge (120r/m)	Financial race conditions (double spend), concurrent redemptions, negative value tampering, discount limit bypass.
POST	/api/offers/reverse/confirm	JWT Bearer (Auth)	Nginx Edge (120r/m)	Financial race conditions (double spend), concurrent redemptions, negative value tampering, discount limit bypass.

6.8 Redemption Service - redemptions.controller.ts (3 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
GET	/api/redemptions/transactions	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/redemptions/discount	JWT Bearer (Auth)	Nginx Edge (120r/m)	Financial race conditions (double spend), concurrent redemptions, negative value tampering, discount limit bypass.
GET	/api/redemptions/report	JWT Bearer (Auth)	Redis Guard + Nginx	SQL Injection in filter/date parameters, resource exhaustion (ReDoS/DoS), unauthorized data export, data exfiltration.

6.9 Reports Service - reports.controller.ts (3 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
GET	/api/reports/analytics	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	SQL Injection in filter/date parameters, resource exhaustion (ReDoS/DoS), unauthorized data export, data exfiltration.
GET	/api/reports/summary	JWT Bearer (Auth)	Redis Guard + Nginx	SQL Injection in filter/date parameters, resource exhaustion (ReDoS/DoS), unauthorized data export, data exfiltration.
GET	/api/reports/report	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	SQL Injection in filter/date parameters, resource exhaustion (ReDoS/DoS), unauthorized data export, data exfiltration.

6.10 Redemption Service - transaction.controller.ts (4 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
GET	/api/transaction/check-bill/:billNumber	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
POST	/api/transaction/send-otp	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/transaction/verify-otp	JWT Bearer (Auth)	Redis Guard + Nginx	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.
POST	/api/transaction/pending	JWT Bearer (Auth)	Redis Guard + Nginx	Broken Object Level Authorization (IDOR), parameter tampering, mass assignment, CSRF.

6.11 Core Service - users.controller.ts (13 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
GET	/api/system-users/roles	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Broken Function Level Auth (BFLA), privilege escalation (vertical), mass assignment of permissions, role tampering.
GET	/api/system-users/roles/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
POST	/api/system-users/roles	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Function Level Auth (BFLA), privilege escalation (vertical), mass assignment of permissions, role tampering.
PUT	/api/system-users/roles/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
DELETE	/api/system-users/roles/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
GET	/api/system-users	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Function Level Auth (BFLA), privilege escalation (vertical), mass assignment of permissions, role tampering.
POST	/api/system-users/register	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Function Level Auth (BFLA), privilege escalation (vertical), mass assignment of permissions, role tampering.
POST	/api/system-users	Public (No JWT)	Redis Guard + Nginx	Broken Function Level Auth (BFLA), privilege escalation (vertical), mass assignment of permissions, role tampering.
GET	/api/system-users/profile	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Function Level Auth (BFLA), privilege escalation (vertical), mass assignment of permissions, role tampering.
PUT	/api/system-users/profile	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Function Level Auth (BFLA), privilege escalation (vertical), mass assignment of permissions, role tampering.
PUT	/api/system-users/profile/password	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Function Level Auth (BFLA), privilege escalation (vertical), mass assignment of permissions, role tampering.
PUT	/api/system-users/:id	JWT Bearer (Auth)	Redis Guard + Nginx	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.
DELETE	/api/system-users/:id	JWT Bearer (Auth)	Nginx Edge (120r/m)	Broken Object Level Auth (BOLA / IDOR), parameter tampering, SQL injection on lookup parameters, unauthorized access.

6.12 Messaging Service - whatsapp.controller.ts (3 Endpoints)

Verb	Endpoint Path	Authentication & Guards	Rate Limit	Auditor Focus / Attack Vectors
POST	/api/whatsapp/upload/file	JWT Bearer (Auth [Roles:])	Nginx Edge (120r/m)	Malicious file upload, magic-byte bypass, CSV/Excel formula injection (XXE), path traversal, DoS via large file.
POST	/api/whatsapp/single/send	JWT Bearer (Auth)	Redis Guard + Nginx	SMS/WhatsApp bombing, international destination abuse, toll fraud, template variable injection, payload spoofing.
POST	/api/whatsapp/send-notification	JWT Bearer (Auth)	Redis Guard + Nginx	SMS/WhatsApp bombing, international destination abuse, toll fraud, template variable injection, payload spoofing.

7. External Third-Party Integrations & Egress Surface

The system interacts with several external cloud providers for transactional delivery, customer communications, and physical artifact generation. Auditors should review outbound communication channels for SSRF, credential handling, and availability resilience:

Integration Provider	Endpoint / Host	Protocol & Auth	Business Function & Security Considerations
TextWare SMS Gateway	https://msg.text-ware.com/send_sms.php	HTTPS POST API User & Key	Transmits critical OTPs and notification SMS. Pentest Focus: Test for SMS bombing via unauthenticated OTP requests and toll fraud targeting premium overseas numbers.
TextWare WhatsApp EMG API	https://message.text-ware.com/emgapi/v1	HTTPS REST Bearer Token OAuth	Dispatches marketing & transactional WhatsApp messages and file assets. Pentest Focus: Inspect media asset uploads for file-type bypass and outbound webhook security.
SendGrid / SMTP Email	smtp.sendgrid.net:587	SMTP over TLS API Key Auth	Sends password activation links, reset tokens, and digital card pass HTML. Pentest Focus: Verify SPF, DKIM, DMARC alignment, email HTML injection, and token exposure in transit.
QR Server API	https://api.qrserver.com/v1/create-qr-code/	HTTPS GET No Auth	Generates dynamic barcode / QR code PNGs for digital membership cards. Pentest Focus: Test parameter manipulation to check for SSRF or payload tampering.

8. Recommended Penetration Testing Scenarios & Checklist

OWASP API1:2023 - Broken Object Level Authorization (BOLA / IDOR)

- Test modifying member_id or id parameters in /api/members/:id, /api/members/card/:id, and /api/categories/:id.
- Verify that customer tokens (role: customer) cannot view or update details belonging to other customer IDs.

OWASP API2:2023 - Broken Authentication & Token Security

- Test brute-force resilience on /api/transaction/verify-otp, /api/members/auth/customer/login/verify, and /api/users/login/verify.
- Test token expiration, algorithm substitution (e.g. alg: none), and signature tampering on JWT access tokens.
- Test refresh token rotation on /api/users/refresh to determine if expired or previously used refresh tokens can be replayed.

OWASP API3:2023 - Broken Object Property Level Authorization (Mass Assignment)

- Submit extraneous fields (e.g. role: superadmin, permissions: {registration: true}) in user update and member registration endpoints.
- Verify that NestJS ValidationPipe({ whitelist: true }) strictly strips unauthorized parameters.

OWASP API4:2023 - Unrestricted Resource Consumption & Rate Limiting

- Verify Nginx gateway rate limits (120 req/min global, 10 req/min auth) cannot be bypassed via X-Forwarded-For or X-Real-IP header spoofing.
- Test concurrent request race conditions on financial redemption endpoints: POST /api/redemptions/discount and POST /api/offers/redeem.

OWASP API5:2023 - Broken Function Level Authorization (BFLA)

- Attempt to access SuperAdmin endpoints (e.g. /api/system-users, /api/system-users/roles, /api/audit/logs) using staff or customer credentials.
- Verify that AuthorizationGuard enforces DB-level permission flags rather than relying purely on client-supplied claims.

OWASP API8:2023 - Security Misconfiguration & Error Leakage

- Trigger database errors and unhandled exceptions across reporting queries to verify that stack traces, SQL syntax, or internal file paths are suppressed by HttpExceptionHandler.